

Issues — Open Workable Items

Revision: 104 **Last modified:** 2026-09-23T16:19:50Z **Ticket prefix:** BOB (operator-mandated, 2026-06-06) **Scope:** Open/active items only. Closed items migrate to Fixed.md.

Tracking: this file + Issues_Summary.md are authoritative for open work. The SQLite single-source-of-truth + docs_chain engine (BOB-010) is complete.

BOB-008 — RuTracker automated login blocked by CAPTCHA

Status: Operator-blocked **Type:** Bug

OPERATOR DECISION (2026-08-26, §11.4.66 interactive clarification): COMPLETE THE CAPTCHA FLOW ONCE

Session establishment path is DECIDED: the operator drives the interactive CAPTCHA flow at `/api/v1/auth/rutacker/captcha` then `/login` once, and the proxy stores the resulting `bb_session`. The cookie-paste path and the cookies-file autoload path were both offered and NOT chosen. THE BLOCK NARROWS BUT DOES NOT LIFT: the operator must physically drive the flow — no agent can solve a CAPTCHA (§11.4.52 honest operator_attended boundary). AGENT PREP OWED BEFORE THE HAND-OFF, so the operator's single attempt succeeds rather than discovering a broken endpoint mid-flow: verify both endpoints are reachable and correctly wired end-to-end, verify the session is actually PERSISTED after a successful post (not merely accepted), and verify a stored session is actually USED by a subsequent search. Honest limitation to state up front: a stored `bb_session` expires, so this path requires repeating — that cost was accepted with the decision.

This answer is recorded as consumer DATA per §11.4.35 — it is the operator’s stated choice, not an agent inference, and supersedes any prior agent-chosen default on this question. Options not chosen are named above so a future reader does not re-litigate a settled call (§11.4.112(5) bounded-verdict discipline applied to decisions).

— prior item text follows —

RuTracker automated login blocked by CAPTCHA

BOB-065 — Lava P2: Egress diagnosis and VPN-host SOCKS routing (containers pkg/egress)

Status: Queued **Type:** Task **Severity:** High

[Backfill from RD2-15/GA-05, audit doc 2026-08-08] Lava-porting finding P2 (Egress decision + VPN-host routing, Lava PLAYBOOK sections 0 and 4). Problem Boba-Base shares: on a datacenter host, trackers are network-blocked (DNS-fail/TLS-MITM, not Cloudflare so FlareSolvrr cannot fix). Affects Jackett indexer fetches + merge_service/download-proxy + plugin engines. Diagnosis (port the script): curl https://api.ipify.org (host IP) + curl -o /dev/null -w % {http_code} https:/// direct vs via a VPN-host SOCKS proxy. Different egress IP + 200 via proxy confirms. Fix: route outbound through a VPN-connected host (the nezha pattern). SOCKS tunnel ssh -D 127.0.0.1:1080 -N (use -socks5-hostname for remote DNS); point Jackett + download-proxy + qBitTorrent-go at it (P3). For browser-cookie harvest, run the harvester ON the VPN host. Port: containers submodule pkg/egress (tunnel up/verify) + scripts/egress-via-vpn.sh glue; reuse Boba-Base existing ensure-macos-tunnel.sh style. TDD: assert the via-proxy egress IP != direct host IP AND a known-blocked tracker returns 200 via proxy. Source: docs/PORTING-FROM-LAVA.md. Per audit RD2-15 [P0]: Create tracked workable items (BOB-064..067) for the four Lava-porting findings, citing implementing commits as evidence, closed as Implemented.

BOB-066 — Lava P3:

BOBA_UPSTREAM_PROXY in download-proxy + qBitTorrent-go + Jackett + compose env-forward

Status: In progress **Type:** Task **Severity:** High

[Backfill from RD2-15/GA-05, audit doc 2026-08-08] Lava-porting finding P3 (Configurable outbound proxy in the services, Lava PLAYBOOK section 3). download-proxy (Python): httpx/requests honor HTTP_PROXY/HTTPS_PROXY/ALL_PROXY/NO_PROXY env natively — add an explicit BOBA_UPSTREAM_PROXY config that sets these for tracker-bound clients, with loopback bypass (NO_PROXY=127.0.0.1,localhost,jackett). qBitTorrent-go: set http.Transport.Proxy (socks5 native, remote DNS) from a BOBA_UPSTREAM_PROXY env — mirror Lava internal/httpx/proxy.go. Jackett: has a built-in proxy setting (configure via its API/ServerConfig). Deploy gotcha (port): the env must be FORWARDED into the containers (docker-compose.yml env / the boba-ctl deploy) — Lava bug was a missing allow-list entry. Verify on distroless via podman inspect, not exec printenv. TDD: a test with a local proxy asserts the service tracker request traverses it; falsifiability: disable the wiring so the test fails. Source: docs/PORTING-FROM-LAVA.md. Per audit RD2-15 [P0]: Create tracked workable items (BOB-064..067) for the four Lava-porting findings, citing implementing commits as evidence, closed as Implemented.

BOB-068 — RD2-00: unattributed, unreviewed Auto-commit mechanism pushing to main

Status: In progress **Type:** Bug **Severity:** High

RD2-00: unattributed, unreviewed Auto-commit mechanism pushing to main

[BOB-136 adoption audit 2026-08-21 -> In progress] Work landed but acceptance NOT met. a7e55f9 completed the Phase-1 investigation (no daemon; shared-checkout race confirmed) and 0972cbc added commit-push-all.sh –scope + challenge, described in its own message as an ‘Interim tooling remedy for BOB-068 while the §11.4.179 architectural

fix (task #67 proposal) is designed'. 35e53db is a DRAFT PROPOSAL only. The §11.4.179 clone-isolation fix is not landed, so the item stays open.

BOB-069 — RD2-40: §11.4.238 QA-discovery-channel ledger — ongoing coverage-escape backfill

Status: In progress **Type:** Task **Severity:** High

RD2-40: §11.4.238 QA-discovery-channel ledger — ongoing coverage-escape backfill

[BOB-136 adoption audit 2026-08-21 -> In progress] a4173c8 stood up the ledger + 4 followups; 709b06c closed 2 Important review findings (CODEGRAPH-1.5.0-GITIGNORE entry, BOB-108 filed). The BOB-009/010 evidence_path gap this item names as remaining open was closed under BOB-086 (f78f383). NOT terminal by the item's own text: it is explicitly scoped 'P1-ongoing', with the full retroactive audit of the ~50 GA-NN/RD2-NN findings deliberately NOT attempted.

BOB-074 — RD2-07: DDoS-class testing fully absent from the mandated test-type matrix

Status: In progress **Type:** Task **Severity:** Medium

RD2-07: DDoS-class testing fully absent from the mandated test-type matrix

[BOB-136 adoption audit 2026-08-21 -> In progress] ae2b5cb authored challenges/scripts/ddos_resilience_challenge.sh (424 lines, 3 public surfaces) + docs/testing/{ddos_resilience,test_type_matrix}.md, so DDoS-class testing is no longer 'fully absent'. But of the three coverages this item's Fix line enumerates, a grep of the shipped challenge finds flood=2 hits, malformed=0, exhaust=0 — malformed-request-flood and resource-exhaustion-under-attack are not covered. 258b7db filed the 6 followups (BOB-109..114). Partial, not complete.

BOB-077 — RD2-10: Identify second host running the Auto-commit rsync/sync mechanism (OPERATOR-DECISION)

Status: Queued **Type:** Task **Severity:** High

OPERATOR DECISION (2026-08-26, §11.4.66 interactive clarification): UNKNOWN — INSTRUMENT THE NEXT OCCURRENCE

The operator does not currently know which host produces the +0500 Auto-commit fast-forwards, so the three candidate answers (second Claude session / intentional rsync job / stale job) all remain open. DECIDED ACTION: stop hunting a host this session cannot reach (§11.4.6 — remote state is not knowable without access) and instead INSTRUMENT the mechanism so the next occurrence identifies itself. Forensic capture to add: committer identity, hostname, timezone offset, push timing, and the git remote used, recorded at Auto-commit time into a tracked forensic log. ACCEPTANCE: the next Auto-commit event yields a captured record naming its origin host — at which point this item resolves to one of the three original branches with evidence rather than a guess. This is the §11.4.101 reversible-safe move: it costs little, blocks nothing, and converts a recurring mystery into a self-identifying event.

This answer is recorded as consumer DATA per §11.4.35 — it is the operator's stated choice, not an agent inference, and supersedes any prior agent-chosen default on this question. Options not chosen are named above so a future reader does not re-litigate a settled call (§11.4.112(5) bounded-verdict discipline applied to decisions).

— prior item text follows —

RD2-10: Identify second host running the Auto-commit rsync/sync mechanism (OPERATOR-DECISION)

BOB-078 — RD2-11: Once identified, wire Auto-commit mechanism through §11.4.234 dedicated commit/push script OR retire it

Status: Queued **Type:** Task **Severity:** High

[Backfill from GOVERNANCE_AUDIT_2026-08-08_ROUND2.md RD2-11, P0] Once identified (RD2-10): either wire it through a real §11.4.234 dedicated commit/push script (with the hook-validation stages this project already has via .claude/settings.json PreToolUse guard, extended to a real pre-commit content check) or shut it down if it serves no purpose. Priority: P0. Blocked on RD2-10.

BOB-080 — RD2-13: Retroactive Fable-xhigh code review of the substantive Auto-commit diffs

Status: Queued **Type:** Task **Severity:** High

[Backfill from GOVERNANCE_AUDIT_2026-08-08_ROUND2.md RD2-13, P1] Retroactively run the mandatory independent Fable-xhigh code review (§11.4.125/§11.4.142/§11.4.209) against the substantive diffs the Auto-commit mechanism introduced (start.sh three new functions especially, since they have zero test coverage — see Root Cause 4 / RD2-24) — even though the changes already landed, a post-hoc review closes the governance gap and will surface RD2-24 (GA-27 missing tests) if not already caught. Priority: P1.

BOB-082 — RD2-15: Create BOB-064..067 workable items for the four Lava-porting findings (closes GA-05)

Status: Queued **Type:** Task **Severity:** High

[Backfill from GOVERNANCE_AUDIT_2026-08-08_ROUND2.md RD2-15, P0 — closes GA-05] Create tracked workable items (BOB-064..067, via the workable-items tool — never raw MD edits) for the four Lava-porting findings, citing implementing commits as evidence, closed as Implemented. GA-05 evidence: `grep -in lava | BOB-06[4-7] docs/Issues.md docs/Fixed.md` returns zero hits. Priority: P0. NOTE: BOB-064..067 have been created 2026-08-10 as Task/Queued (the four Lava P1..P4 items); the closed-as-Implemented status flip (citing per-finding implementing commits) remains owed under this item.

BOB-085 — RD2-18: Create top-level Boba proxy/merge-service v1.0.0 readiness ledger (closes GA-10)

Status: Queued **Type:** Task **Severity:** Medium

[Backfill from GOVERNANCE_AUDIT_2026-08-08_ROUND2.md RD2-18, P2 — closes GA-10] Create the top-level Boba (proxy/merge-service) v1.0.0 readiness ledger (GA-10) — dedupe with the browser_extension existing one as the template. GA-10 evidence: only docs/RELEASE_READINESS_20260616.html/.md/.pdf (dated point-in-time snapshot) and the extension own ledger exist; no top-level proxy/merge-service ledger created. Priority: P2.

BOB-088 — RD2-21: Complete/verify README Tracked-Items + Status Documents table row-completeness (GA-07 remainder)

Status: Queued **Type:** Task **Severity:** Medium

[Backfill from GOVERNANCE_AUDIT_2026-08-08_ROUND2.md RD2-21, P1] Complete/verify the README Tracked-Items + Status Documents table row-completeness (GA-07 remaining half). Not independently re-verified this round whether every mandated doc (CONTINUATION.md, Issues.md, Fixed.md, PORTING-FROM-LAVA.md, both new GA/RD2 audit docs, every Status.md/Status_Summary.md pair) actually has a row. Priority: P1.

BOB-090 — RD2-25: HelixQA Challenge entry exercising all three start.sh subcommands end-to-end against real compose stack

Status: In progress **Type:** Task **Severity:** Medium

RD2-25: HelixQA Challenge entry exercising all three start.sh subcommands end-to-end against real compose stack

[BOB-136 adoption audit 2026-08-21 -> In progress] a9366c9 bumped submodules/helixqa to HelixDevelopment/qa@00c5ca4 adding banks/boba-start-sh-reload.yaml (3 cases, all three subcommands). The bank

EXISTS but has never been EXECUTED: the commit states honestly that the helixqa binary was not built in-session (§11.4.3 SKIP feature_disabled_by_config) and ‘live bin/helixqa list demo is deferred’, with only YAML-parse evidence captured. This item’s acceptance is end-to-end execution against the real compose stack — artifact-class evidence cannot close a runtime-class acceptance (§11.4.226).

BOB-093 — RD2-28: Live compose bring-up + verify rutracker ReDoS regex bounds deployed to container (closes runtime half of GA-12)

Status: In progress **Type:** Task **Severity:** High

RD2-28: Live compose bring-up + verify rutracker ReDoS regex bounds deployed to container (closes runtime half of GA-12)

[BOB-136 adoption audit 2026-08-21 -> In progress] 1c0389a proved 3 of the 4 sub-steps with strong runtime evidence: the bounded regex is confirmed in the DEPLOYED /config/qBittorrent/nova3/engines/rutracker.py inside the running container (sha256 76a6bd2e..), with a self-validated challenge + §11.4.115 RED (mutated unsafe form FAILs) and GREEN verdict JSON. The 4th sub-step is NOT met: ‘capture timing of a large rutracker result page (<2s)’ was not exercised — in docs/qa/BOB-093/live_search_smoke.txt rutracker returned status=empty, results_count=0 in 164ms, so no large page was ever timed.

BOB-094 — RD2-29: Author tests/stress/test_tracker_fetch_stress_chaos.py with §11.4.85 fault injection

Status: In progress **Type:** Task **Severity:** Medium

RD2-29: Author tests/stress/test_tracker_fetch_stress_chaos.py with §11.4.85 fault injection

[BOB-136 adoption audit 2026-08-21 -> In progress] The suite landed (test file at 4b7b21d, evidence + RED-on-mutated-classifier capture at f3ca131) with 9 test functions: 2 stress, 3 boundary, 3 chaos (network_drop, midflight_kill, input_corruption), 1 category_map. This item explicitly requires fault injection across process-kill, network-

fault AND resource-exhaustion. Only 2 of those 3 classes are present — there is no resource-exhaustion scenario in tests/stress/test_tracker_fetch_stress_chaos.py. Partial.

BOB-095 — RD2-30: Author tests/stress/test_scheduler_hooks_sse_stress_chaos.py for Go-side triangle

Status: In progress **Type:** Task **Severity:** Medium

RD2-30: Author tests/stress/test_scheduler_hooks_sse_stress_chaos.py for Go-side triangle

[BOB-136 adoption audit 2026-08-21 -> In progress] d5c8c3e authored qBitTorrent-go/internal/service/sse_broker_stress_chaos_test.go (462 lines, 6 scenarios, 2 RED captures) and found+fixed a real double-unsubscribe ‘close of closed channel’ defect. But this item names a THREE-component triangle: sse_broker.go + internal/api/hooks.go + internal/api/scheduler_api.go. Only sse_broker.go is covered — there is no stress_chaos test anywhere under qBitTorrent-go/internal/api/. 1 of 3, partial.

BOB-097 — RD2-32: Author DDoS-class coverage for exposed download-proxy/merge endpoints (canonical impl of RD2-07)

Status: Queued **Type:** Task **Severity:** Low

[Backfill from GOVERNANCE_AUDIT_2026-08-08_ROUND2.md RD2-32, P3] Author DDoS-class coverage (RD2-07) for the exposed download-proxy/merge endpoints. Priority: P3.

BOB-100 — RD2-39: Bump submodules/jackett one commit (canonical impl of RD2-09)

Status: Queued **Type:** Task **Severity:** Low

[Backfill from GOVERNANCE_AUDIT_2026-08-08_ROUND2.md RD2-39, P3] Bump submodules/jackett one commit (RD2-09). Priority: P3.

BOB-101 — GA-19/RW-09: Is --profile go parity still a release goal? (gates RW-10..13) — OPERATOR-DECISION

Status: Queued **Type:** Task **Severity:** High

OPERATOR DECISION (2026-08-26, §11.4.66 interactive clarification): DEFER PAST v1.0.0

Go --profile go parity remains a goal but is NO LONGER a v1.0.0 release blocker. RW-10..13 move to a post-1.0 milestone and stop gating the tag. Nothing advertised is removed, so §11.4.122 stays clean and no §11.4.90 Obsolete closure is warranted. The BOB-141 measured fact stands unchanged: the Go container's Dockerfile runs ONE binary binding only :7187; nothing binds :7186 or :7188 despite compose setting PROXY_PORT/BRIDGE_PORT. CLAUDE.md's port map already describes what the container ACTUALLY does and needs no amendment under this decision.

This answer is recorded as consumer DATA per §11.4.35 — it is the operator's stated choice, not an agent inference, and supersedes any prior agent-chosen default on this question. Options not chosen are named above so a future reader does not re-litigate a settled call (§11.4.112(5) bounded-verdict discipline applied to decisions).

— prior item text follows —

GA-19/RW-09: Is --profile go parity still a release goal? (gates RW-10..13)
— OPERATOR-DECISION

BOB-102 — RW-05: LAN-exposure threat model — bind tunnel 127.0.0.1 or keep 0.0.0.0? — OPERATOR-DECISION

Status: In progress **Type:** Task **Severity:** Medium

OPERATOR DECISION (2026-08-26, §11.4.66 interactive clarification): KEEP 0.0.0.0 + MANDATORY AUTH GUARD

The tunnel STAYS LAN-reachable — no bind address changes to 127.0.0.1. The operator explicitly chose to preserve access from other devices on the network. THE DECISION CARRIES A BINDING OBLIGATION: a permanent §11.4.135 regression guard MUST land that FAILS THE BUILD if any LAN-reachable route ever stops demanding authentication. The operator accepted 0.0.0.0 ON THE CONDITION that guard exists — without it this decision is unprotected and the item is NOT closeable. Guard requirements: enumerate routes from the authoritative source (FastAPI app, Go handlers, boba-jackett) never a hand-maintained list; resolve real auth coverage not a grep for the string ‘auth’ (§11.4.201 real-condition); deliberately-public routes exempt ONLY via a checked-in list with per-entry justification, enumerated as honest gaps never silent; golden-TRUE + golden-FALSE fixtures per §11.4.107(10).

This answer is recorded as consumer DATA per §11.4.35 — it is the operator’s stated choice, not an agent inference, and supersedes any prior agent-chosen default on this question. Options not chosen are named above so a future reader does not re-litigate a settled call (§11.4.112(5) bounded-verdict discipline applied to decisions).

— prior item text follows —

RW-05: LAN-exposure threat model — bind tunnel 127.0.0.1 or keep 0.0.0.0? — OPERATOR-DECISION

BOB-104 — §11.4.238 followup: CodeGraph 1.5.0 nested-.gitignore regression challenge

Status: In progress **Type:** Task **Severity:** Medium **Created-By:** Claude

Coverage-escape followup (docs/QA_DISCOVERY_LEDGER.md, BOB-075 agent-code-reading finding, commit e6162f7): CodeGraph 1.5.0 (up from documented 0.9.9) walked into nested-.gitignore-excluded frontend/node_modules and extension/node_modules (32,260 files / 514,456 nodes vs the 2026-06-06 baseline of 509 files / 8,906 nodes) instead of honoring frontend/.gitignore + extension/.gitignore per git check-ignore -v. Author a challenge (challenges/scripts/codegraph_gitignore_honor_challenge.sh or equivalent, e.g. wrapping ‘codegraph doctor –sniff-gitignore-honor’ if that subcommand exists, else a real re-index + file-count assertion) with §11.4.115 RED_MODE polarity: RED_MODE=1 reproduces the blowup against the live nested-.gitignore tree, RED_MODE=0 asserts the resync stays within the documented baseline order of magnitude. Full evidence: docs/

codegraph/Status.md lines 91-118. UPSTREAM FILED 2026-08-18: real upstream repo is github.com/colbymchenry/codegraph (npm package @colbymchenry/codegraph, confirmed via package.json + gh repo view; NOT vasic-digital/codegraph, correcting this ledger's original assumption). Issue: <https://github.com/colbymchenry/codegraph/issues/1567> (full reproduction evidence: git check-ignore -v re-verified first-hand; two bounded synthetic repro attempts up to 63 nested .gitignore files / 960 files against the actual installed v1.5.0 binary did NOT reproduce the blowup in isolation – honest negative result, root cause not pinned to a specific line in either scanning implementation). Draft PR (diagnostic only, not a behavioral fix): <https://github.com/colbymchenry/codegraph/pull/1568> – adds a logDebug() call so a future report can confirm which of the two independent gitignore-respecting code paths (git-ls-files-based vs filesystem-walk fallback) actually ran. Both PRs/issue filed via SSH (Hard Stop #2) from a fork at github.com/milos85vasic/codegraph. Status: In-progress pending upstream maintainer triage/merge – boba-side closure of this item still needs the RED/GREEN challenge script (§11.4.115) authored per the original scope, independent of upstream's response.

BOB-106 — §11.4.238 followup: §11.4.84 quiescence-check helper for the unattributed auto-commit path

Status: Queued **Type:** Task **Severity:** Medium **Created-By:** Claude

Coverage-escape followup (docs/QA_DISCOVERY_LEDGER.md RD2-00/BOB-068 entry, docs/GOVERNANCE_AUDIT_2026-08-08_ROUND2.md RD2-00): 20 bare 'Auto-commit' commits exist in this repo's git history (confirmed via git log --oneline --all --grep, e.g. 54e313f/9c8f684/743097a/de9270b/1c36777/41179c2/7c529ca) with no ATM-NNN reference and no TDD trail, landing via ordinary git pull fast-forward from a second session/host with push access to the same remotes (mismatched commit timezone vs the investigating host, per RD2-00 Update). §11.4.84 working-tree-quiescence has no mechanical guard on this path — no gate flags a commit reaching main with a bare/templated message and no ticket citation. Author a §11.4.84 quiescence-check helper (e.g. challenges/scripts/no_unattributed_autocommit_challenge.sh) that scans the commit range since the last known-good release tag and FAILs on any commit message matching a closed bare/templated pattern (e.g. ^Auto-commit\$, ^sync:) with no ATM-NNN or task/PR reference, wired into

scripts/pre_build_verification.sh or the §11.4.234 commit-push-all.sh entrypoint. BOB-068 (RD2-00) remains the tracking item for identifying/stopping the source; this item is specifically the new automated CHECK.

BOB-107 — §11.4.238 followup: pre-dispatch existence check for subagent task-brief source inputs

Status: Queued **Type:** Task **Severity:** Medium **Created-By:** Claude

Coverage-escape followup (docs/QA_DISCOVERY_LEDGER.md SCRATCH-LOSS-2026-08-18 entry, evidence: .superpowers/sdd/task-phase1a-report.md line 21): the Phase 1a subagent (a1cc331d) discovered at task start that 5 source files its brief named as required reads (curriculum_amendment_plan_v1.md, ai_curriculum_modules_27_35_extracted.md, and 3 curriculum_analysis_modules_*.md gap analyses) were absent from the session scratchpad — root cause per that subagent’s own investigation: the prior producer subagent (ae59171f) hit its session rate limit (a §11.4.147(e) API-quota crash) before writing them. curriculum_amendment_plan_v1.md remains absent from the live scratchpad as of this session’s re-check. No mechanical check verifies a task brief’s declared input files exist and are non-empty before the downstream consumer subagent is dispatched. Author a pre-dispatch precondition helper (project-side orchestration tooling, e.g. a small script the conductor runs before Task/Agent dispatch when a brief names required input paths) that fails closed with an actionable ‘missing input, respawn the producer’ message rather than silently letting a downstream agent proceed on absent evidence and fabricate content unsupported by its named sources.

BOB-109 — BOB-074 followup: scaling-class test coverage absent from mandated test-type matrix

Status: Ready for testing **Type:** Task **Severity:** Medium **Created-By:** Claude

docs/testing/test_type_matrix.md's §11.4.27 test-type audit found zero scaling-class coverage anywhere in the tree (no scaling-tagged directory, test file, or HelixQA bank distinguishes growing-dataset/tracker-count/concurrent-user scale-out from stress-under-burst). Scope at least one scaling dimension, e.g. tracker-count scale-out in merge search against challenges/helixqa-banks/boba-services.yaml's tracker set, or the qbittorrent-proxy-go –profile go swap, with a real measured baseline.

BOB-110 — BOB-074 followup: UX-class test coverage (accessibility/usability) absent

Status: Queued **Type:** Task **Severity:** Medium **Created-By:** Claude

docs/testing/test_type_matrix.md's §11.4.27 test-type audit found UI functional coverage (Vitest + Playwright) but nothing framed around usability/accessibility/UX outcomes specifically. Scope an axe-core or equivalent accessibility pass over the Angular frontend, covering WCAG checks, keyboard-nav coverage, and screen-reader labeling.

BOB-111 — BOB-074 followup: configure real rate limiting for boba's 3 public HTTP endpoints

Status: In progress **Type:** Task **Severity:** High **Created-By:** Claude

Source inspection across the whole stack (2026-08-18) verified no rate-limit mechanism exists for :7185 (qBittorrent WebUI proxy), :7187 (merge search service), or :7189 (boba-jackett) – no slowapi/limiter/throttle import in download-proxy/src/, no rate-limit middleware in qBitTorrent-go/internal/middleware/ (only cors.go + logging.go) or internal/jackettapi/ (only auth/cors middleware tests, no rate middleware), and no nginx/reverse-proxy service in docker-compose.yml. Candidate remediations documented in docs/testing/ddos_resilience.md: nginx-in-container reverse proxy with limit_req_zone (most portable, adds a container); a FastAPI slowapi dependency for the merge-search service; a Gin rate-limit middleware for boba-jackett following the existing internal/middleware/ pattern. qBittorrent's own WebUI bandwidth-shaping settings were NOT verified to cover request-rate (only bandwidth) – do not assume they close this gap without checking.

BOB-114 — BOB-074 followup: self-validation golden-bad fixture for the rate-limit detector

Status: Queued **Type:** Task **Severity:** Medium **Created-By:** Claude

challenges/scripts/ddos_resilience_challenge.sh's `--self-validate` mode currently only ships a golden-bad fixture for the crash-resistance detector (per §11.4.107(10)/§11.4.201). The rate-limiting detector has no matching golden-bad fixture proving it would actually FAIL a synthetic no-rate-limit-enforced artifact, so an unvalidated rate-limit detector could silently pass a broken/absent rate-limit deployment. Add a synthetic fixture (e.g. a stub server that never returns 429/503 under burst) and assert the detector correctly reports the absence, closing the self-validation gap for this detector class.

BOB-121 — External watchdog for the forced-logout architectural gap (task #85, incident #3)

Status: Ready for testing **Type:** Task **Severity:** Important **Created-By:** Claude

Phase 1 design-only proposal: the BOB-116/task-77 resource-pressure preventive systemd `--user` timer runs inside `user@1000.service`, the exact pool it monitors, so it cannot fire when that pool dies (proven by incident #3, docs/qa/BOB-120/, 22:42+22:57 fires then blocked 23:45:49-23:49:00). Recommends Option B (user crontab reusing pre-existing `crond.service` in `system.slice`, no new root service) kept alongside the existing timer, with Option A (new root-owned systemd unit) as escalation path if Phase 1.5 live cron/cgroup verification is adverse. Proposal: docs/proposals/external-watchdog-for-forced-logout-architectural-gap.md. Operator decision required per §11.4.66 before any implementation – NOT implemented in this task.

Progress 2026-08-21: Flight recorder built, installed, and recording. First finding: NOTHING was watching at all — the root watchdog is `LoadState=not-found` and the BOB-116 user timer inactive. The blocking spike REFUTED the proposal's rationale while confirming its conclusion: this `vixie-cron` does invoke `pam_systemd` so the tick lands in `session-N.scope`, but that scope is a SIBLING of `user@1000.service`, and the real incident killed exactly one unit (73 `'user@1000.service:`

Killing process' lines while session-18.scope merely deactivated). So the recorder does not need to survive — its SCHEDULER does, and crond in system.slice survived all seven incidents. Captures the pre-event memory/PSI/thread ramp that nothing post-hoc can recover, plus boot id, the gap itself, unit start timestamp, cgroup pids, and OOM cgroup attribution. Evidence: 5 records under real cron at exact 60s spacing; a staged analogue on a DISPOSABLE unit reaching 'VERDICT: SESSION TEARDOWN'; golden-good against the REAL BOB-120 log giving the correct diagnosis (k_unit_kill=1, k_oom=0); healthy-host quiet under load 8.15. NOT CLOSED — two operator decisions are owed: whether to keep it installed (one crontab line, zero signals, zero power verbs, 32K, reversible via uninstall.sh), and the root system.slice watchdog which is written but needs one su. UNTESTED AGAINST A REAL FORCED LOGOUT: survival is inferred from cgroup topology, not observed, and it does NOT hold against a whole-slice sweep or KillUserProcesses=yes. ## BOB-135 — Test isolation: test_list_hooks_after_create fails in bulk suite (Permission denied /config)

Status: Ready for testing **Type:** Bug **Severity:** Low

Task #109 subagent found: tests/unit/
test_merge_api_route_contracts.py::TestHooksEndpoint::test_list_hooks_after_create fails when run in bulk suite order with 'ERROR
api.hooks:hooks.py:102 Failed to save hooks: [Errno 13] Permission denied: /config'. Passes in isolation (2.02s clean). Root cause: full-suite ordering pollution — some earlier test leaves state that makes hooks try to write to /config (which the test env doesn't own). Pre-existing, unrelated to BOB-126/BOB-129 chain. Fix strategy: identify the polluting test, add teardown or use a proper tempdir fixture for hooks storage in the offending test.

BOB-137 — Merge service on 7187 wedges while the same process still serves 7186 (GIL starvation by one spinning thread)

Status: In progress **Type:** Bug **Severity:** High **Created-By:** Claude

Reported-Via: §11.4.202 reporting directive bug on 2026-08-20T14:46:52Z **Reported-By:** Claude

What (the report, verbatim): The merge service on port 7187 wedges after hours of uptime: the port stays bound and the container keeps reporting “healthy”, but every HTTP request hangs until the client times out. Measured 2026-08-20 16:41 UTC+2 on a container up 3h53m:

```
curl http://localhost:7186/ -> HTTP 200 in 0.096s (proxy, same process)
curl http://localhost:7187/ -> HTTP 000 after 6.0s (merge service,
WEDGED)
```

Both ports are served by the SAME process (pid 2330069, fd 3 = 7186, fd 7 = 7187), so this is not a crashed worker – one loop inside a live process has stopped servicing requests while another in the same process is fine.

Thread state at the time of the wedge (/proc/2330069/task, 16 threads): -
tid 2330529: state R, wchan 0 <- ONE thread spinning on CPU - tid
2330528: state S, wchan do_sys_poll <- the healthy 7186 poll loop - the
other 14: state S, wchan futex_wait_queue

That is the GIL-starvation signature: a thread busy-looping in Python holds the GIL and every other thread queues on the GIL futex. 7186 survives because do_sys_poll releases the GIL; the 7187 async loop needs sustained GIL time to service a request and starves. Process CPU was 20.6% while idle.

Corroborating evidence: seven sockets held by the process sit in CLOSE-WAIT with unread bytes still in the receive queue (Recv-Q 162, 162, 162, 79, 1, 1, 1) – clients sent a request and hung up, and the app never read it or closed the fd. The listener had also accumulated an unaccepted backlog (Recv-Q 6 on the 7187 LISTEN socket) at first observation. The container log’s last line is 2h before the observation, so the service processed nothing in that window.

NOT fd exhaustion: only 48 of 16384 fds were open.

ROOT CAUSE NOT ESTABLISHED. All four while True loops in the service (routes.py:166, search.py:1169, streaming.py:161, streaming.py:359) are correctly bounded and awaited, so the spin is not a naive unslept loop. py-spy could not attach to name the spinning frame – the host has kernel.yama.ptrace_scope=1, which denies non-child attach. Per the §11.4.102 Iron Law no fix is proposed until the spinning frame is identified.

Next diagnostic step: obtain a Python stack. Either run py-spy INSIDE the container (musl wheel), or set ptrace_scope=0 for the duration of one dump, or add a SIGQUIT/faulthandler.register() dump hook to main.py so the running service can be asked for its own stacks without ptrace.

DISCOVERY CHANNEL (§11.4.238): found by an agent probing the host by hand while investigating an unrelated test-suite result – NOT by automated QA. This is a coverage escape in its own right; see the sibling item on the health check that was structurally incapable of observing it.

Affected scope / file-scope manifest: download-proxy/src/main.py, download-proxy/src/merge_service/, download-proxy/src/api/streaming.py, docker-compose.yml (qbittorrent-proxy)

Reproduction / context: Leave the qbittorrent-proxy container running for several hours with search traffic (a full tests/security run is sufficient). Then: curl -max-time 6 http://localhost:7186/ returns 200; curl -max-time 6 http://localhost:7187/ returns 000. Confirm with: ss -ltnp | grep 7187 (unaccepted backlog) and awk '{print \$3}' /proc//task/*/stat (one R thread, rest futex_wait_queue).

Acceptance criteria: The spinning frame is identified from a real Python stack dump (not inferred), the busy-loop is fixed at its root, and a regression guard proves 7187 still answers after a sustained-traffic soak. Evidence: before/after curl timings on both ports plus a thread-state census showing no permanently-R thread.

[BOB-136 adoption audit 2026-08-21 -> In progress] 1dd7b0a ESTABLISHED the root cause with captured evidence (16 stack dumps showing Deduplicator.merge_results() called synchronously at search.py:914 on the event-loop thread; loop thread sustained 81-98% user-space CPU while all other threads showed d_untime=0). The remediation landed under BOB-145 (0572b71, now Fixed), whose own text is headed 'BOB-145 - the 7187 wedge' and which refuted the assumed $O(N^2)$ cause by profiling. BOB-137 and BOB-145 therefore describe the SAME defect; per §11.4.214 that is a link/dedup decision, not a unilateral close, and no post-fix re-observation of the multi-hour wedge is recorded against BOB-137 itself. Left open pending that linkage decision.

Live verification 2026-08-21 — REDUCED BUT NOT ELIMINATED. Deliberately NOT closed.

The service was confirmed running POST-FIX bytes before any measurement, six independent ways: served sha256 == committed == worktree across 20 merge-service/api/main files; fix markers 10 inside the container vs 0 at the pre-fix commit; .pyc header decode showing embedded source mtime+size matching the actual file (so the import reused it and the loaded module was compiled from exactly this source); fix markers present in the LOADED bytecode; and the process starting 823s AFTER the fix hit disk. A first attempt at this comparison reported routes.py as stale — an INSTRUMENT ARTIFACT (marshal back-reference encoding differs between a fresh compile and a pyc load), caught before it became a false positive.

Soak, same script and concurrency, precondition reached (11,340 results over 516 tracker responses / 12 searches ~ 945 per merge, larger than BOB-145's N=800 maximum):

PRE-FIX (quoted from the recorded report):	22 of 26 probes dead on 7187 (84.6%)
POST-FIX (measured):	2 of 141 dead (1.4%)

The dead-count alone understates the residual: 25.5% of probes stalled >1s (<0.1s 65.2% / 0.1-1s 9.2% / 1-5s 18.4% / >=5s 5.7% / dead 1.4%). Both dead events show the exact BOB-137 asymmetry — 7186 answering in 0.077s while 7187 timed out at 10s — and both coincide with the loop thread sampled at state R with wchan=0, the GIL-starvation signature (tid independently confirmed as the loop thread by its idle wchan do_epoll_wait).

WHY THIS ROW STAYS OPEN: the acceptance evidence this item names is '22/26 dead -> 0/N dead'. Achieved: 22/26 -> 2/141. The user-visible symptom — 7187 unresponsive while 7186 answers in the same process — STILL OCCURS, twice in 15 minutes. That is precisely BOB-145's own predicted residual: search.py:914 is still a plain synchronous call, and removing the symptom needs a change at that CALL SITE (offload or await), which BOB-145 explicitly scoped out.

Two criteria that ARE satisfied: no permanently-R thread (48 of 80 census samples had zero R threads), and the in-process 20s watchdog logged 0 stalls — with a control needle, since that same watchdog produced 167,971 bytes of dumps pre-fix. ## BOB-143 — Orphaned .worktrees/ dirs (46M, unresolvable gitdir) pollute gate scan scope and manufacture false BOB-126-class findings

Status: Queued **Type:** Bug **Severity:** Medium **Created-By:** Claude

Reported-Via: §11.4.202 reporting directive bug on
2026-08-20T15:08:18Z **Reported-By:** Claude

What (the report, verbatim): `.worktrees/ci-split-workflows/` (13M) and `.worktrees/completion-initiative-phase-0/` (33M) are ORPHANED: `git worktree list` reports only the main checkout, so neither is a registered worktree. Each contains a `.git POINTER FILE` whose target `gitdir` no longer exists, so `git` cannot resolve HEAD, branch, or status inside them – every query returns empty.

They are gitignored (`.gitignore:122`), so nothing tracks them and nothing will ever notice them drifting.

WHY THIS IS NOT COSMETIC: they pollute the scan scope of whole-tree gates and manufacture false findings. Measured 2026-08-20 by the §11.4.32 sweep:

- `cm_test_mock_pid_explicit_int` reported 2 violations at `tests/unit/merge_service/test_deadline_tunable.py:44` – BOTH inside these orphaned trees. The MAIN tree's copy of that file is already hardened (it sets `mock.pid = 12345` and patches `os.killpg/os.getpgid`) and passes the gate cleanly. The finding read as a live §11.4.263 / BOB-126-class defect and was not one.
- 6 of the 57 “missing anchor carrier” files flagged by the propagation gates were likewise `.worktrees/**`.

That is the §11.4.201(1) false-positive shape sourced from scan scope, and it costs real investigation time: a reader triaging “2 live BOB-126 violations” reasonably treats it as a host-safety emergency.

CLARIFICATION (established during triage, so the record is not alarming): these trees are NOT a kill(-1) vector. Their `download-proxy/src/merge_service/ search.py` contains ZERO `os.killpg` calls – they predate that cleanup code entirely – so there is no unguarded signal call to reach. Additionally `pyproject.toml` sets `testpaths = ["tests"]`, so a plain `pytest` run does not collect from `.worktrees/`. No host-safety risk was found. The defect is scan-scope noise plus 46M of unreferenced disk.

WHY REMOVAL IS NOT DONE AUTONOMOUSLY (§11.4.122 / §11.4.124 / §11.4.101): because `git` cannot resolve their HEAD, it is NOT possible to prove their contents are merged into main. Deleting unprovenance work is exactly the irreversible, operator-owned decision §11.4.122 reserves. Two options for the operator: (a) confirm removal (they are stale dev scratch dirs) – reversible only from backup, so a

§9.2 pre-op backup should precede it; or (b) keep them and add .worktrees/ to the gate scan-scope exclusion list as a §11.4.224(E)-fenced, checked-in, justified entry.

Either way the exclusion list is the cheaper immediate mitigation and does not destroy anything.

Affected scope / file-scope manifest: .worktrees/ci-split-workflows/, .worktrees/completion-initiative-phase-0/, gate scan-scope config

Reproduction / context: git worktree list shows only the main checkout; git -C .worktrees/

log -1 returns empty (gitdir target missing). Run the §11.4.32 sweep and observe cm_test_mock_pid_explicit_int report 2 violations, both under .worktrees/, while the main-tree file passes the same gate.

Acceptance criteria: Whole-tree gates no longer report findings sourced from orphaned worktrees: either the dirs are removed after operator confirmation with a §9.2 pre-op backup, or .worktrees/ is added to a checked-in §11.4.224(E)-fenced exclusion list with justification. Verify by re-running the sweep and confirming zero .worktrees-sourced findings.

BOB-151 — CM-SCRIPT-DOCS-SYNC is a named gate with no implementation, and 24 of 36 scripts have no companion doc

Status: Queued **Type:** Task **Severity:** Medium **Created-By:** AI

Reported-Via: §11.4.202 reporting directive task on 2026-08-21T15:05:33Z **Reported-By:** AI

What (the report, verbatim): The §11.4.18 script-documentation rule names a gate CM-SCRIPT-DOCS-SYNC, but no executable file in this repository implements it. Because nothing measures the obligation, 24 of 36 scripts under scripts/ have no docs/scripts/.md companion - two thirds of them. This is the named-gate ledger gap the constitution itself warns about: a gate that is named but never implemented reads as coverage while providing none, and the corpus grows words instead of enforcement. Surfaced while writing the two ownership companions, which were themselves

only written because the feature plan asked for them explicitly - not because any gate demanded it. Filing rather than absorbing: an unstated finding reads as no finding, and a 67% documentation gap that nothing reports will not shrink on its own.

Affected scope / file-scope manifest: `scripts/.sh`, `docs/scripts/.md`, `scripts/pre_build_verification.sh`

Reproduction / context: `grep -rl CM-SCRIPT-DOCS-SYNC --include='.sh' --exclude='.py' .` (excluding submodules) -> 0 files. Control needle in the same command shape: `CM-OWNERSHIP-INVARIANTS` -> 3 files, `CM-KILLPG-PGID-GUARD` -> 7 files, so the search is not blind. Then: `for s in scripts/*.sh; do [ -f docs/scripts/${basename $s .sh}.md ] || echo missing; done` -> 24 of 36 missing.

Acceptance criteria: Either the gate is implemented and the 24 missing companions are written (the count becoming a monotone-decreasing ratchet so it cannot grow), or the obligation is explicitly scoped down to a defined subset with the reason recorded. What is NOT acceptable is the current state, where the rule is stated and nothing measures it.

BOB-159 — Warm `./start.sh` over an already-running stack leaves the FR-004d repair window open

Status: Queued **Type:** Bug **Severity:** Medium **Created-By:** T041 independent review (IMPORTANT-2), partially remediated

OPERATOR DECISION (2026-08-26, §11.4.66): REPAIR, THEN RE-VERIFY UNTIL STABLE

The warm `./start.sh` path keeps running the ownership repair against a live stack, but walks, re-verifies, and repeats until a pass finds nothing new. Options not chosen: refuse the repair while the stack is up and direct the operator to `--recreate`; stop the stack on the warm path too (correct but ends 'warm'); accept and document the window. WHY THIS MATTERS MORE THAN A NORMAL ITEM: this is the exact defect the whole 002-user-owned-downloads feature exists to end. The `--recreate` path was already fixed to order precondition -> down -> repair -> up so the walk sees a tree no container can write. The warm path was not, so a container can create a new non-owned file AFTER the repair has

passed that directory — the ownership problem leaking back in through the other door. REQUIRED BY THE CHOSEN OPTION, and it is the hard part: the loop MUST be BOUNDED, and on giving up it MUST report honestly that ownership is UNPROVEN rather than silently exiting 0 (§11.4.201(6) — a loop that stops finding new files because it ran out of iterations returns the same quiet zero as a genuinely clean tree). An active download creating files faster than the walk completes is the realistic non-converging case and must be named in the give-up message.

Recorded as consumer DATA per §11.4.35 — the operator's stated choice, not an agent inference. Options not chosen are named so a future reader does not re-litigate a settled call.

— prior item text follows —

Reported-Via: §11.4.202 reporting directive bug on
2026-08-21T19:01:17Z **Reported-By:** T041 independent review
(IMPORTANT-2), partially remediated

What (the report, verbatim): The `--recreate` path was fixed this round: `run_ownership_precondition -> stack_down -> run_ownership_repair -> stack_up`, so the repair walks a tree no container can write to. That ordering is now asserted behaviourally by three new checks in `tests/unit/test_start_reload_recreate.sh`, each killed by its paired 1.1 mutation (11/11 RED-OK).

The WARM path is NOT covered by that fix and this item tracks the remainder. On a warm `./start.sh` the gate runs before THIS invocation brings anything up, but if the stack is ALREADY running, containers write while the repair walks. A container can then create a new non-operator-owned file BEHIND the walk, after which the completion marker records complete over a tree that is not, and those stragglers are never repaired without a manual `--force`.

BOUNDED, not dismissed: after any successful pass the marker is valid for the scope fingerprint and the repair short-circuits without walking (`marker_is_valid`), so the window requires a stale-or-absent marker AND a live stack together. Declaring a new scope entry re-arms the marker, which is exactly how that combination arises in practice.

NOT DONE THIS ROUND, with the reason stated rather than hidden: the clean guard is a cheap marker-only probe mode on scripts/ownership_repair.sh that answers has-this-scope-been-repaired without walking the tree. The existing `-dry-run` cannot serve: it deliberately SKIPS the marker fast-path (`FORCE=0 && DRY_RUN=0` guard) and always walks, so using it as a warm-start probe would walk the tree twice on every start. Adding that mode requires editing ownership_repair.sh, which another stream was actively editing during this round; duplicating marker_is_valid into start.sh instead would be a near-identical fork (11.4.251). Deferred to this item rather than done unilaterally or silently.

The misleading comment at the warm-start call site (which claimed the gate runs before any container writes) has been corrected to state this boundary honestly.

Affected scope / file-scope manifest: start.sh (warm-start dispatch, run_ownership_gate call site); scripts/ownership_repair.sh (marker fast-path)

Reproduction / context: 1. Ensure the stack is UP. 2. Change config/owned_paths.yaml so the scope fingerprint changes (this re-arms the marker by design, data-model E2). 3. Run a warm ./start.sh (no `-recreate`). 4. The ownership repair walks and chowns the declared tree while containers are still running and able to write into it.

Acceptance criteria: A warm ./start.sh cannot complete an ownership repair while a container that writes to a declared location is running. Either the repair is deferred with an actionable refusal naming `-recreate`, or the stack is quiesced for the walk. Asserted behaviourally in tests/unit/test_start_reload_recreate.sh alongside the existing PRECONDITION_BEFORE_DOWN / REPAIR_AFTER_DOWN / REPAIR_BEFORE_UP checks, each with a paired 1.1 mutation that kills it.

BOB-162 — Two new guards exist but no seam invokes them — plus the brownfield adoption decision the commit guard needs

Status: Queued **Type:** Task **Severity:** Medium **Created-By:** BOB-106/BOB-107 remediation, residual

Reported-Via: §11.4.202 reporting directive task on 2026-08-21T19:35:02Z **Reported-By:** BOB-106/BOB-107 remediation, residual

What (the report, verbatim): The TESTS for both guards are now executed: pre-build invariant 30's glob was extended from tests/unit + tests/pre_build to also cover tests/hooks. MEASURED before/after: the glob expanded to 27 suites with 0 under tests/hooks while 3 existed there; it now expands to 30 with 3 under tests/hooks. All three pass.

But the GUARDS themselves are still invoked by nothing.

check-brief-inputs.sh is honestly conductor-run rather than automatic: a brief's required-input list lives in free-form prose that the Agent tool's structured input does not expose, so an automatic prompt-scraping gate would itself be an unproven pattern-match. Its seam is the dispatch procedure, and that is a documentation + habit change, not a hook.

unattributed-commit-guard.sh is different and is why this item exists. Run against real history it names 14 violating commits since the last tag (and 21 bare Auto-commit subjects exist across all refs). Wiring it into the pre-build or commit seam AS-IS would therefore refuse every commit immediately, on pre-existing debt nobody can fix in the moment.

That is precisely the 11.4.224(E) brownfield-adoption shape, and 11.4.66/11.4.122 put the choice with the operator, not with an agent inventing a ratchet. The options, stated so the decision is a decision and not a default: (a) immediate hard floor – the seam refuses until all 14 are attributed; (b) one-time monotone-decrease ratchet (the 11.4.135 pattern) – snapshot 14 as the baseline, the count may fall and may never rise, so day one is green and the disease cannot spread; (c) changed-commits-only –

gate only commits created from now on, with a scheduled deadline for the historical 14; (d) report-only for a stated period, then escalate.

Recommendation, with the reasoning rather than just the pick: (b). It is the pattern this constitution already uses for exactly this situation, it makes the debt visible and bounded immediately, and it cannot be satisfied by deleting the guard's name (11.4.227 closes that gaming channel). But it is the operator's call and this item is not closed until that answer is recorded.

Honest boundary (11.4.6): this item does NOT claim the 14 commits are harmful in themselves – it claims their CONTRIBUTION is absent and that nothing currently prevents the 15th.

Affected scope / file-scope manifest: scripts/hooks/unattributed-commit-guard.sh; scripts/hooks/check-brief-inputs.sh; scripts/pre_build_verification.sh; scripts/commit-push-all.sh

Reproduction / context: Both guards run correctly by hand and are covered by passing tests (9/9 and 15/15, each proven non-bluff against a no-op stub). Neither is invoked by scripts/pre_build_verification.sh or scripts/commit-push-all.sh, so neither exerts standing detection pressure (11.4.226: a guard with no execution seam is not coverage; registration is not coverage).

Acceptance criteria: Each guard is invoked by a named seam, OR carries a registered deferral pointing at this item. For unattributed-commit-guard.sh specifically, the operator has answered the adoption question below and the answer is recorded as consumer DATA – never an invented ratchet.

BOB-164 — Live dashboard fails WCAG AA colour contrast on 21 nodes — brand heading measures 1.43:1 against a 3:1 floor

Status: In progress **Type:** Bug **Severity:** Medium **Created-By:** BOB-110 UX-class coverage, discovered by the new axe-core suite on its first live run

Reported-Via: §11.4.202 reporting directive bug on 2026-08-21T19:56:53Z **Reported-By:** BOB-110 UX-class coverage, discovered by the new axe-core suite on its first live run

What (the report, verbatim): This is a REAL user-facing defect, not a test-tuning artifact, and it was found by the automated regime rather than by a human squinting at the page – which is exactly the 11.4.238 posture the project is aiming for.

The static-grep oracle would NOT have found it. Measured: the served root ships an empty pre-hydration, so any check reading the raw HTML audits a page nobody sees. The violation only exists in the hydrated DOM, which is why 11.4.170 requires a rendered oracle and forbids value-equality assertions as the proof a UI is correct.

Severity reasoning, stated rather than assumed: this is user-visible and affects the primary dashboard heading, but it degrades legibility rather than breaking function, and the surface is operator-facing rather than public. Medium, not High.

The failing test was left FAILING on purpose (11.4.238) instead of silenced or marked xfail. tests/ux/ currently reports 1 failed, 16 passed; that 1 is this defect. Anyone reading a red UX suite should read it as this item, not as flakiness – and when this is fixed the suite goes fully green, which is the signal that it is closed.

HONEST SCOPE LIMIT (11.4.6): only the dashboard landing view was scanned. The /jackett/* sub-routes and the ng-serve-hosted :4200 route set were NOT audited – the commands to close both are recorded in docs/testing/ux_accessibility.md. So this item's 21 nodes are a floor, not a total.

Affected scope / file-scope manifest: the Angular dashboard served at http://localhost:7187/ (same compiled SPA as frontend/); production component CSS, not test files

Reproduction / context: Run tests/ux/test_live_dashboard_accessibility.py against the running merge service. axe-core v4.13.0, scanning a real Playwright-rendered JS-hydrated DOM, reports color-contrast violations on 21 nodes. Measured pairs: .brand / h1 text #9d001e on background #3c3f41 = 1.43-1.62:1 (WCAG AA large-text floor is 3:1); tagline #808080 on #3c3f41 = 2.68:1 (body-text floor is 4.5:1).

Acceptance criteria: axe-core reports ZERO color-contrast violations against the live rendered dashboard, with the fix made in production component CSS rather than by relaxing the assertion or excluding the rule (11.4.120: reconcile to the correct mechanism, never weaken the check). The existing tests/ux/ suite is the guard and already fails today, so the RED is captured – closure requires it flipping GREEN against the live surface, which is runtime-class evidence per 11.4.226.

BOB-170 — Capture one quiescent GREEN run of the scaling growth gate, which has never executed under its own loadavg<=0.75/cpu precondition and has no scheduled window that would make it

Status: Queued **Type:** Task **Severity:** Medium **Created-By:** Claude **Assigned-To:** Claude

WHAT. The BOB-109 scaling suite gates its two timing tests on $\text{loadavg_1m/nproc} \leq 0.75$ — on this 8-cpu host, a 1-minute load average at or below 6.0 — and SKIPS loudly otherwise. That gate is correct and was adopted for a good reason (§11.4.201(8)): the author validated a 2.10 growth-exponent threshold, then observed it FALSE-FAIL correct code at load 11.06 (baseline span 2.136), and at load 15-23 measured baseline spans of 2.358 against injected-cubic mutants at 2.278-2.331 — the signal is smaller than the noise and the two are not separable in either direction. Gating was the honest response.

THE PROBLEM. The gate has consequently NEVER RUN under its own precondition. Every recorded run today measured load 9.15-23; the independent reviewer measured 9.66 during review; the conductor measured 6.45 at its lowest. GREEN polarity WAS observed — at loads 9.4-11.6 (span 1.882) and in three stability runs (1.759/1.832/1.848) — but never once beneath the shipped ceiling. The author states this honestly as an inference from data rather than a run they can paste, and the reviewer confirmed the inference is sound (quiescence is strictly more favourable). Sound inference is still not an observed run.

WHY THAT MATTERS (§11.4.226). A registered, topology-present guard that never executes is indistinguishable from a guard that would fail if it did. Nothing currently ensures it ever runs: no freshness contract, no scheduled quiet-window invocation, no tracked item — which is precisely the unexecuted-standing-guard class §11.4.226 names, where registration gets treated as coverage while execution is nobody's job. The forensic precedent in that anchor is two standing guards that, when finally executed, immediately emitted latent FAILs.

ACCEPTANCE. (a) Execute both quiescence-gated timing tests on a host whose 1-minute loadavg is genuinely $\leq 0.75/\text{cpu}$ — no agent fleet, no concurrent build — and capture the run as an artifact showing the resolved load reading alongside the measured span exponent, so the precondition is provable from the artifact and not asserted. (b) Record the observed GREEN polarity in the item and in the test source, replacing the current honest-inference note. (c) If the gate FAILS under genuine quiescence, that is the finding this item exists to surface, and it reopens the threshold-calibration question rather than being worked around. (d) Establish a freshness contract per §11.4.226: how stale a quiescent verdict may be before the gate counts as uncovered again, so this does not silently return to never-executing.

HONEST BOUNDARY. This item does not claim the gate is wrong. The evidence points the other way — quiescence is strictly more favourable than the loads where GREEN was already observed. It claims only that the run has not happened, and that an unexecuted guard cannot be cited as coverage.

PROVENANCE. Raised as IMPORTANT-2 by the independent Fable-substrate reviewer of the BOB-109 work, and independently corroborated: the reviewer verified the SKIP is loud and prints its resolved numbers, and confirmed the shipped tests do SKIP at today's load.

BOB-172 — rutracker search endpoint returns HTTP 403 with Cloudflare challenge markers and zero login markers, so one of three merge-search trackers silently contributes no results

Status: Ready for testing **Type:** Bug **Severity:** High **Created-By:** Claude **Assigned-To:** Claude

WHAT. The rutracker SEARCH endpoint is refused by bot protection while the site itself is fully reachable. Measured unauthenticated 2026-08-21 (no cookie file read, no credential value in any artifact — §11.4.10):

GET /forum/index.php -> 200, 96283 B,

, challenge markers 0 GET /forum/tracker.php?nm=debian -> 403, 5351 B, challenge markers 1, LOGIN markers 0, trs-tr- 0

The zero login markers are the load-bearing detail: the server is not asking us to authenticate, it is refusing the request before authentication is considered. Supplying valid credentials or a fresh cookie jar therefore does NOT address this.

WHY IT MATTERS. rutracker is one of the three trackers the merge service fans a query across (with kinozal and nnmclub). A 403 on its search path means it contributes nothing to every merged result set, silently — the fan-out still ‘succeeds’, it just returns one fewer tracker’s worth of results. From a user’s seat this looks like thin results, not an outage.

IT EXPLAINS TWO PREVIOUSLY-UNEXPLAINED OBSERVATIONS. docs/qa/BOB-093/live_search_smoke.txt records rutracker returning status=empty, results_count=0 in 164ms, and the BOB-136 adoption audit reached the same observation independently. Both recorded the symptom; neither had the cause. 164ms is far too fast for a real search across a remote forum and is exactly what an immediate 403 costs.

IT ALSO BLOCKS BOB-093’s FOURTH SUB-STEP. That item requires timing a large rutracker result page under 2s. No large page has ever been obtained, and this is why. That sub-step is not merely waiting on credentials, as previously assumed — it is unmeetable until the 403 is resolved.

PROVENANCE, INCLUDING A CORRECTION I MADE MID-INVESTIGATION (§11.4.199). An independent reviewer reported a Cloudflare challenge served to curl even with cookies. Verifying, I probed index.php, got a clean 200 with no challenge markers, and was one step from recording their claim as REFUTED. That would have been wrong for a textbook reason: index.php is not the search path, so my probe never reached the precondition, and a repro that misses the precondition proves nothing — it is not evidence of absence. Probing the actual search endpoint reproduced it immediately. The reviewer was substantially right; my probe was aimed at the wrong endpoint. Recorded because the near-miss is the instructive part, and because the two probes TOGETHER give a sharper result than either the original claim or my near-refutation: not ‘rutracker is behind Cloudflare’ (the index is open), but ‘the SEARCH endpoint specifically is refused’.

ACCEPTANCE. (a) Determine whether the 403 is permanent policy, rate/reputation-based, or triggered by a client signature the plugin can legitimately present (user-agent, header order, TLS fingerprint) — by measurement, not assumption, and WITHOUT evasion techniques that would violate the site’s terms. (b) Whatever the outcome, the failure must become LOUD: a tracker returning 403 must be reported as a tracker ERROR in the merge result, never folded into ‘empty’ — a silent contributor is the §11.4.201(6) false-null at the product layer, and it is what let this sit unexplained across two separate investigations. (c) A test asserting that a 403 from any tracker surfaces as an error and not as zero results, with a paired §1.1 mutation. (d) If the endpoint is genuinely unavailable to us, record that as an honest capability boundary (§11.4.112) and stop advertising rutracker as a live search source until it is — including in the README and the merge-service docs.

HONEST BOUNDARY. Measured from ONE host, ONE time, UNAUTHENTICATED. Whether an authenticated session with a browser-like client succeeds was NOT tested and must not be assumed either way. The finding is that the current code path gets a 403; it is not a claim about what every client would get.

BOB-175 — update --location Fixed --status can still mint a row that update's own validator rejects, because the status- location guard is one-directional

Status: Queued **Type:** Task **Severity:** Low **Created-By:** Claude
Assigned-To: Claude

WHAT. The workable-items update seam guards the status-location invariant in one direction only. After BOB-166, update --status <terminal> on an Issues-located row is refused. The mirror is still open: update --location Fixed --status <non-terminal> exits 0 and creates a row that update's own validator immediately rejects.

Verified empirically by the independent reviewer of BOB-166:

```
update --location Fixed --status 'In progress' -> exit 0
validate                                         -> FAILS,
naming the row (check (f), fixedLocationNonTerminalStatus)
```

So the command can still mint a state its own validate call refuses. That is the §11.4.196(F) shape at the seam layer: the invariant is CONFIGURED in validate but not ENFORCED at every write path that can violate it.

WHY IT WAS DELIBERATELY LEFT OPEN IN BOB-166, and why that was right. Three reasons, all checked rather than asserted: (1) the real corpus has ZERO instances of this direction against TEN of the direction BOB-166 closed — the asymmetry in the data matched the asymmetry in the code; (2) detective coverage ALREADY existed and demonstrably fires, so unlike BOB-166's direction this cannot rot silently; (3) and the load-bearing one — reopenCmd documents and SANCTIONS a transient Fixed-plus-non-terminal state via its --location Fixed operator override. A naive preventive guard at the update seam would collide with that override's semantics. Closing this therefore requires a design decision about how the two interact, which is a different question from the one BOB-166 was scoped to answer, and expanding that item would have meant shipping the decision unexamined.

ACCEPTANCE. (a) Decide and RECORD how a preventive guard on this direction coexists with reopenCmd's sanctioned override — this is the actual work, and the answer should be written down

rather than inferred from whatever the patch does. Candidates worth weighing: exempt the reopen path explicitly, require an override flag on update mirroring reopen's, or leave the direction detective-only with the rationale recorded so the asymmetry is a decision rather than an oversight. (b) If a guard lands, it reuses `terminalStatuses()` — BOB-166 established one predicate source specifically so the two directions cannot drift. (c) Paired §1.1 mutation. (d) NEGATIVE CONTROL (§11.4.201(1)), and it is the sharp one here: the sanctioned reopen path **MUST** still work. A guard that breaks `reopenCmd`'s documented override is a false-positive refusal, and worse than the gap it closes, because it breaks a workflow operators are told to use.

HONEST BOUNDARY. This is not a live data defect. Zero corpus instances, and the detective gate catches it at the next validate. It is filed so a scoped, deliberate omission stays visible as a tracked decision instead of living only in a code comment where the next reader will mistake it for an oversight (§11.4.197: a started thread reaches a documented terminal state, never quiet abandonment).

PROVENANCE. Raised by the implementing agent of BOB-166 as a known asymmetry it deliberately did not close, independently verified and endorsed as an acceptable scope boundary by that item's reviewer, on the condition that it become a tracked item rather than a comment. This is that item.

BOB-179 — Two adjacent tracker false-null classes remain open and must be stated as gaps, not implied closed

Status: Queued **Type:** Task **Severity:** Medium **Created-By:** Claude **Assigned-To:** Claude

WHAT: the BOB-172 independent review demonstrated two further paths that still report a refusing or unreachable tracker as an empty result. Both are PRE-EXISTING and neither is a regression from BOB-172, but the fix evidence log presents the five-site coverage without stating the boundary (11.4.194(5) requires un-analysed dimensions be explicit gaps, never silently assumed safe).

GAP A – exception before `resp.status` is read. Reviewer probe B, captured: a connection-refused rutracker yields `status=empty`, `error=None`, `http_status=None`, `metadata.errors=[]`, `metadata.status=completed`. Each *search** method swallows exceptions (except `Exception: logger.error`; return results) before `_search_one`'s error handling can see them, so a tracker that is DOWN is indistinguishable from one that is genuinely empty.

GAP B – soft refusal at HTTP 200. Reviewer probe A, captured: `_classify_upstream_http_status(200, )` returns `None`, which is CORRECT by design (a 2xx is a usable response; body-marker triggering would risk the over-fire the negative controls exist to prevent). But all five search GETs use `aiohttp`'s default `allow_redirects=True`, so a session-expiry 302 -> login-page-200 chain parses to zero rows and reports empty.

FIX DIRECTION: Gap A needs the exception to reach a diagnostic rather than being swallowed. Gap B needs a DISTINCT detector (final-URL check or login-form marker) with its own RED – explicitly NOT a widening of the status-code trigger.

ACCEPTANCE: both gaps closed with their own REDs, or explicitly closed per 11.4.112 with evidence. Immediate sub-task: append a stated-gaps paragraph to `docs/qa/BOB-172/fix_evidence_20260822.log`.

BOB-184 — Icon-glyph controls are unverified for non-text contrast because neither contrast oracle can measure them

Status: Queued **Type:** Task **Severity:** Medium **Created-By:** Claude **Assigned-To:** Claude

Three icon-glyph controls (`.bridge-retry`, `.theme-toggle`, `.caret`) render text made of non-BMP code points. `axe-core` declines to decide their contrast, reporting them under the incomplete channel with messageKey `nonBmp` and resolving NEITHER `fgColor` NOR `bgColor`, so the Python recomputation in `docs/qa/BOB-164/axe_contrast_scan.py` cannot decide either: 40 such nodes across 16 palette x mode combinations. BOB-164 round 2 stopped them being scored as silent passes by naming them `GLYPH_UNMEASURED`, printing them on every run and fencing

them, so any NEW unmeasured glyph node blocks. What remains genuinely unproven is their contrast itself: as non-text user-interface components they owe 3:1 under WCAG SC 1.4.11, and no oracle in this repo measures that today. Acceptance: a measurement path that resolves the effective foreground and backdrop for glyph controls (for example reading `getComputedStyle` colour against the composited backdrop, or replacing the glyphs with inline SVG carrying explicit fill tokens), each of the three controls shown to clear 3:1 in all 16 palette x mode combinations, and the GLYPH_UNMEASURED fence shrunk by exactly the nodes then proven.

BOB-185 — Rendered-DOM contrast oracle cannot see data-driven nodes, leaving badge and status pills arithmetic-only

Status: Queued **Type:** Task **Severity:** Medium **Created-By:** Claude **Assigned-To:** Claude

`docs/qa/BOB-164/axe_contrast_scan.py` scans a static dist with no backend, so every node whose existence depends on fetched data is absent from the page it measures: the results table renders empty, so `.type-badge` and `.quality-badge` never appear, and the hooks list renders empty, so `.status pills` never appear. That is precisely why the BOB-164 round-1 regression went unseen in a rendered DOM even though it was scanned in all 16 themes, and it is why round 2 had to close the class in the arithmetic oracle instead. Those nodes are now covered by `frontend/src/app/models/style-contrast.spec.ts`, which extracts declared foreground-on-fill pairs from the stylesheets, but that is an ARITHMETIC claim about declared colour pairs, not a rendered-pixel one: it cannot see opacity applied by an ancestor, a composited backdrop, or a cascade this repo's static extractor does not model. Acceptance: the scan drives the dashboard with seeded fixture data (a stub backend, a route fixture, or an injected component harness) so the badge and status nodes are present in the DOM, axe measures them directly, and a control needle proves the rendered oracle sees a seeded sub-floor badge before any clean result from it is believed.

BOB-187 — ownership_precondition.sh is unfenced: same unreviewed .env-driven scope as the now-fenced repair, still writes probe files at any declared path

Status: In progress **Type:** Bug

scripts/ownership_precondition.sh consumes the SAME unreviewed .env-driven scope as ownership_repair.sh and creates probe files inside it, but it is NOT fenced. T028 remediation added ownership_path_fence() to scripts/lib/ownership.sh and wired it into ownership_repair.sh, closing the path-escape class there; the precondition was outside that agents file scope and still accepts whatever config/owned_paths.yaml expands to. Blast radius is lower than a recursive chown (it writes probe files rather than mutating ownership of an existing tree) but the INPUT is identical and equally unreviewed, so the same QBITTORRENT_DATA_DIR value that would have driven a filesystem-wide chown will drive probe-file creation at an arbitrary location. Note the escape is empirically confirmed for the repair path, not merely reasoned: during T028 remediation a probe declaring the verbatim shipped entry with QBITTORRENT_DATA_DIR=/ hung the suite, and ps showed the real artifact executing “find / (! -uid 1000 -o ! -gid 1000) -printf ...” before it was killed by verified pid. Acceptance: ownership_precondition.sh calls the SAME ownership_path_fence() predicate from scripts/lib/ownership.sh (never a second dialect, 11.4.251), refuses fail-closed on a rejected entry, and ships a paired 1.1 mutation proving the refusal fires PLUS a negative control proving the six live shipped entries still ACCEPT so the fix is not a 11.4.201(1) false-positive refusal. Discovered out-of-band during T028 remediation and reported by the agent as needing tracking, so it is also a 11.4.238 coverage escape.

BOB-188 — Gate invariant 17 runs a STALE TRACKED binary that structurally cannot see the violations it exists to catch

Status: In progress **Type:** Bug

OPERATOR DECISION (2026-08-26, §11.4.66 interactive clarification): UNTRACK THE BINARY — BUILD ON DEMAND

§11.4.30 answer, recorded as consumer DATA: the compiled workable-items binary is NOT to be git-tracked. ‘Any build derivate which we can recreate by executing proper mechanism for generating MUST NOT be versioned’ applies without exception here. Keeping it tracked with only the invariant-52 fingerprint gate, and keeping it tracked with a commit-time rebuild, were both offered and NOT chosen. REQUIRED END STATE: the gate builds from source, or REFUSES HONESTLY when the Go toolchain is absent (§11.4.201(11) — probe the artifact through its real invocation path, never fake a pass, never silently fall back to a stale binary). Staleness becomes structurally impossible rather than merely detected. ACCEPTED COST: a fresh clone needs a Go toolchain before invariant 17 can run — already true for the qBitTorrent-go backend, so this adds no new host requirement. The invariant-52 fingerprint gate remains useful as defence-in-depth for as long as any binary exists on disk.

This answer is recorded as consumer DATA per §11.4.35 — it is the operator’s stated choice, not an agent inference, and supersedes any prior agent-chosen default on this question. Options not chosen are named above so a future reader does not re-litigate a settled call (§11.4.112(5) bounded-verdict discipline applied to decisions).

— prior item text follows —

pre_build_verification.sh invariant 17 (CM-WORKABLE-ITEMS-VALIDATE) resolves its binary through the candidate loop at :534, whose FIRST entry is constitution/scripts/workable-items/bin/workable-items. That file is GIT-TRACKED (md5 17644a248363, identical to bin/workable-items-linux) and executable, so it WINS resolution over the current untracked sibling constitution/scripts/workable-items/workable-items (md5 43376a6d0184). The tracked binary is STALE: it does not contain the guards its own source now has.

MEASURED, needle-proven, 2026-08-25. String presence in the tracked binary: “refusing to set terminal status” -> 0; “Issues-location item has TERMINAL status” -> 0; control needle from the SAME updateCmd, “at least one mutable field flag is required” -> 2 (so the instrument sees through that path and the zeros are real

absences, not a blind read). The untracked sibling returns 1 / 1 / 2 for the same three queries. A check whose message string is absent from the binary cannot fire.

RUNTIME PROOF: the same injected violation (a row set to terminal status while current_location=Issues) run through both binaries -> stale reports 1 violation (only the body_md desync class), current reports 2 including the location-status class verbatim. This is exactly why the ten BOB-166 rows (BOB-087/129/131/144/145/146/148/153/155/157) survived undetected: the gate that was supposed to catch them was running a binary structurally incapable of seeing them.

The 11.4.108 SOURCE->ARTIFACT gap: source correct, artifact stale, every gate reading the artifact reports green. This is the THIRD instance of that class found in one session, alongside BOB-169 (a charset gate that never opened a file) and BOB-183 (a served bundle five days older than its sources).

COMPOUNDING: the comment at :519-523 directly above the loop asserts “The naive bin/workable-items path never existed in this checkout (bin/ is a gitignored local build-output dir nothing ever populated)”. That statement is now FALSE - bin/ holds two tracked binaries. A stale comment asserting the absence of the very file that now shadows resolution is how this stayed invisible.

Also an 11.4.30 question the operator owns: bin/workable-items and bin/workable-items-linux are VERSIONED BUILD ARTIFACTS in a constitution submodule that is inherited by reference by every consumer, so every consumer inherits whichever binary was last committed. Flagged independently by two separate agents this session.

ACCEPTANCE: (a) resolution must never prefer a stale artifact over a current one - either the tracked binaries are removed and resolution falls through to build-on-demand, or a freshness check refuses a binary older than its sources (see the BOB-183 fingerprint gate for a working pattern); (b) the false comment at :519-523 corrected; (c) a paired 1.1 mutation proving the new refusal fires, plus a negative control proving a genuinely fresh binary still passes so the fix is not an 11.4.201(1) false-positive refusal; (d) the 11.4.30 tracked-binary decision recorded as operator DATA. Discovered out-of-band during BOB-166 remediation - a 11.4.238 coverage escape in its own right.

BOB-191 — Fail-open scanner is a MATCHER hole blind to 5 enumerated languages (Go/Rust/Ruby/C/...) — enumerated-but-unanalysable prints PASS instead of SKIP (§11.4.201(6))

Status: Queued **Type:** Bug

WHAT: the §11.4.252 fail-open scan reports 0 hits for qBitTorrent-go, and that zero is NOT evidence. The triage agent ran control needles through the scanner's own path per §11.4.201(7)(b): a Python 'except Exception: pass' needle was SEEN, a TypeScript 'catch (e) {}' needle was SEEN (so frontend/src's zero IS a real zero), but a Go empty-'if err != nil {}' needle was NOT SEEN. An instrument that cannot see the idiom returns the same quiet zero as a clean tree, and only one of those is honest. DISTINCT FROM BOB-189, deliberately not merged with it per §11.4.214: BOB-189 is a false MATCH (fail-closed guards reported as fail-open); this is a false NULL (an entire language unscanned). Same scanner, opposite failure directions, different fixes - merging them would hide one behind the other. IMPACT: Go is the language of qbittorrent-proxy-go and boba-jackett (port 7189, which owns encrypted tracker credentials), so the unscanned surface is exactly where §11.4.252's credential-plus-mutation combination is most likely. Nobody has assessed it; the dashboard says clean. ACCEPTANCE: the scanner grows a Go arm covering the empty-err-block and swallowed-error idioms, its needle is SEEN through the real path, qBitTorrent-go's result is re-derived, and every finding is triaged as this Python/TS pass was. Until then qBitTorrent-go's fail-open posture is UNKNOWN and must be reported as UNKNOWN, never as 0.

BOB-192 — Remediate the 6 ratcheted CM-NO-FAIL-OPEN-SKIP findings — each needs a live-stack-verified classify-or-fail rewrite

Status: Queued **Type:** Task

WHAT: the BOB-161 gate lands with 6 real fail-open skips RATCHETED rather than fixed. Ratcheting is the constitution's named brownfield default (§11.4.135/§11.4.224(E)) and this repo's own precedent, so the choice is correct - but the remediation it defers is real work that must be owned somewhere. WHY THIS ITEM EXISTS: the gate's own header asserted the 6 were 'TRACKED SEPARATELY (§11.4.197)' while no tracker row existed. The §11.4.209 independent review verified the absence and raised it as IMPORTANT-5, noting that without a row those findings are precisely the parked-unverified debt class §11.4.226(4) names - the population an operator samples and finds broken. A prose claim of being tracked is not tracking. WHAT EACH NEEDS: a skip that fires on evidence the host ANSWERED must either classify the response and FAIL on it, or take a §11.4.69 reason that is honestly derivable from the environment rather than from the response - verified against the live stack, not asserted. Two of the six sit under '# allow-skip:' markers at tests/unit/test_tracker_auth_live.py:105 and :108, which the reviewer confirmed genuinely are fail-open, so that marker must not be treated as absolution. ACCEPTANCE: all 6 remediated with RED-first evidence per §11.4.115, the gate's BASELINE ratcheted to 0, and the ratchet's monotone-decreasing property preserved throughout (§11.4.227(A)). NOTE the reviewer's MINOR-1: a count-baseline absorbs a one-out-one-in swap, so remediation progress must be checked against the finding SET, not only the count.

BOB-194 — Pre-build gates walk .claude/worktrees, so a stale agent worktree can fail the main build (§11.4.201(1))

Status: In progress **Type:** Bug

WHAT: agent worktrees under .claude/worktrees/ are ephemeral copies pinned at arbitrary commits - never built, never shipped, deleted when the agent finishes. Pre-build gates that walk the tree with find(1) from the repo root descend into them anyway. MEASURED INSTANCE (2026-08-25): CM-GO-TOOLCHAIN-MATCHES-BUILDER FAILED the main build with exactly one finding, from .claude/worktrees/agent-afda1df906c537ab4 - a worktree 86 commits behind still carrying 'FROM golang:1.23-alpine' against a go.mod long since at 1.26.2. The main tree was CORRECT throughout. Per §11.4.201(1) a false-positive refusal is a

FAIL-bluff of equal severity to a false pass: it blocks real work and teaches people to bypass the gate. FIXED FOR ONE GATE: '.claude' added to that gate's PRUNE_DIRS with a deterministic \$1.1 pair - a stale mismatch inside .claude/worktrees must NOT fail a healthy tree, the SAME mismatch outside it MUST still fail, so the prune cannot widen into blindness (§11.4.201(6)). Mutation verified: reverting the prune fails 2 checks. SURVEY, measured not inferred: 8 of 13 pre_build gates walk the tree; only the fixed one prunes .claude. Gates using 'git ls-files' are structurally immune - worktrees are untracked. Empirically probed: check_cm_closure_seam_binds, check_cm_killpg_pgid_guard and check_cm_no_production_mutation_residue all rc=0 with ZERO worktree references - clean in practice today. UNMEASURED, not clean: check_cm_test_mock_pid_explicit_int and check_cm_test_mock_pid_patched_when_real_pid were not reached before the probe budget expired. HYPOTHESIS REFUTED, recorded so nobody re-walks it: an earlier revision of this item speculated that check_cm_plugin_count's 90s timeout was caused by walking worktrees. It is NOT. That gate's find is scoped to \$PLUGINS_DIR (check_cm_plugin_count.sh:224), so worktrees are outside its walk entirely. Its slowness is real - still running past 54s on a re-measure - but has a different, still-unidentified cause and belongs to its own item, not this one. ACCEPTANCE: every tree-walking gate either prunes agent scratch or is proven immune by measurement, each with a paired mutation. NOTE the asymmetry that bounds the risk: a stale worktree can only ADD findings to a security-relevant scan (killpg, mutation-residue), never remove them - so the exposure is false refusal and eroded trust, not a missed defect.

BOB-196 — check_cm_plugin_count runs for over a minute on ~69 files — cause unidentified, and it is not worktree traversal

Status: Queued **Type:** Task

WHAT: the CM-PLUGIN-COUNT pre-build gate takes 189 SECONDS to verify 8 documented counts. Measured 2026-08-25: exceeded a 90s probe budget (rc=124), then a bounded re-run completed at 'rc=0 wall=189s' - it PASSES, it is simply slow. CAUSE, MEASURED NOT GUESSED: the marker loop at

check_cm_plugin_count.sh:273-290 iterates EVERY LINE of every governed document and spawns a pipeline per line. Per iteration: 'printf | grep -oE | wc -l | tr -d' (4 processes) plus 'printf | sed -n' (2) = ~6. Governed docs are AGENTS.md 689 + CLAUDE.md 494 + docs/features/Status.md 670 = 1853 lines, so ~11,118 process spawns, measuring ~102 ms/line. Classic per-line-subprocess shell trap. THE IRONY WORTH PRESERVING, because it explains why nobody simplified it: the in-code comment shows '-oE | wc -l' was chosen DELIBERATELY over 'grep -c' after measuring the §11.4.201(12) footgun - on this host (ugrep 7.8.4) 'grep -coE' returned 3 at top level but 1 inside a 'set -euo pipefail' subshell, a context-dependent reading. The correctness fix is right and must be kept; it is the PER-LINE application of it that costs the three minutes. HYPOTHESIS REFUTED, recorded so nobody re-walks it: this is NOT worktree traversal. The gate's find is scoped to \$PLUGINS_DIR (:224), so the five agent worktrees are outside its walk. That guess was raised on BOB-194 and is dead. LIKELY FIX (unverified, stated as a candidate not a conclusion): pre-filter with ONE grep for lines containing 'CM-PLUGIN-COUNT:' before entering the loop, reducing ~1853 iterations to the ~8 lines that carry a marker, while leaving the per-line parsing logic - and its footgun-avoiding form - completely unchanged. WHY IT MATTERS beyond impatience: this gate is on the pre-build critical path, and CLAUDE.md leans on it as the mechanical authority for the three distinct plugin rosters (43 curated / 43 engines / 12 bootstrap) whose conflation was BOB-149. A gate slow enough to tempt anyone into skipping it protects nothing. ACCEPTANCE: runtime reduced with the counts and the footgun-avoiding parse preserved byte-for-byte in behaviour, proven by the existing paired mutation still biting plus a before/after wall-clock recorded. §11.4.6: nothing here questions the gate's VERDICTS - only its runtime.

**BOB-211 — LATENT + OPERATOR-GATED:
on a uid-flattening mount whose uid is
not the operator, chown fails EPERM with
no fstype-aware diagnosis, and fmask/
dmask silently defeat the preserve_mode
600 contract**

Status: Queued **Type:** Bug **Severity:** minor

STATUS: LATENT on this host (measured: all six declared locations sit on ONE btrfs mount, fully ownership-expressive) and OPERATOR-GATED for verification. Retained from the dismissed BOB-206 rather than discarded with it, because the scenario is well-founded elsewhere: the declared mount is a udisks auto-mounted REMOVABLE NVMe, so another operator's portable drive being exFAT or NTFS is entirely ordinary.

TWO RESIDUALS: (1) REPAIR-LAYER DIAGNOSIS. On a uid-flattening mount whose flattened uid is NOT the operator, probe_location correctly REFUSES (verified: uid=0 and uid=100999 both refuse). But it then hands ownership_repair.sh a chown that will return EPERM, and nothing in the repair path is fstype-aware — so the operator sees a permission failure whose real remedy is a REMOUNT OPTION, which no message says. Reasoned, NOT proven: the shim used to verify BOB-206 models the stat READ, not the chown WRITE, and cannot settle whether chown actually fails. (2) MODE CONTRACT. vfat flattens MODE via fmask/dmask, so the preserve_mode: true / 600 contract on .env and config/boba.db would be silently unenforceable there. §11.4.10-adjacent: a credential file believed to be 600 that is world-readable by mount option is a leak the mode check cannot see.

WHY OPERATOR-GATED: a genuine end-to-end RED needs a real uid-flattening mount. The privilege-free route is bindfs -u (FUSE; fusermount IS present and user_allow_other IS set) — but bindfs is ABSENT on this host, as are mkfs.vfat and losetup. So verification needs either a bindfs install or a privileged loopback mount. Neither was attempted (§11.4.21 — high-blast-radius host mutation is operator-gated).

ALSO RECORDED: NO test anywhere exercises a uid-flattening filesystem — vfat/exfat/ntfs/flatten/loopback/mkfs/losetup/bindfs/fusermount all measure 0 across the three ownership test files, needle-proven (probe_location = 3 hits through the same instrument).

ACCEPTANCE: (1) operator decides whether to install bindfs or provide a privileged loopback so the RED can be built; (2) if verified, the repair path gains fstype-aware diagnosis naming the remount remedy; (3) the mode contract either detects mode-flattening mounts and refuses, or documents honestly that it cannot be enforced there.

DISCOVERY CHANNEL (§11.4.238): retained residual from the BOB-206 verification stream.

BOB-219 — LIVE §11.4.65 sync violation: docs/guides/tracker-credentials. {html,pdf} exist on disk but are untracked and ignored, while their .md source IS tracked

Status: Queued **Type:** Bug **Severity:** major

WHAT, conductor-verified: docs/guides/tracker-credentials.md is TRACKED. Its §11.4.65-mandated export twins docs/guides/tracker-credentials.html and .pdf both EXIST ON DISK, are NOT tracked, and ARE ignored — matched by the .gitignore *credentials* deny-all at :31. The .md is rescued by an explicit allowlist entry at :38; nobody added entries for the twins.

WHY IT IS A LIVE VIOLATION AND NOT A HYPOTHETICAL:
§11.4.65 requires every in-scope Markdown document to carry synchronized .html/.pdf siblings, and §11.4.212 requires every §11.4.65-scope doc to be reachable from the README. Two artifacts that exist locally but can never be committed are, from any fresh clone, ABSENT — so every clone of this repository has a tracker-credentials guide with no exports, while the authoring host looks complete. The divergence is invisible on the machine that would notice it.

WHY NOBODY SAW IT: this is a §11.4.201(6) FALSE-NULL of the BOB-212 class. git status never listed the twins, so no gate and no author had a signal. The blind instrument and the clean tree return the identical quiet zero.

ANOTHER INSTANCE OF THE SAME MECHANISM, filed here rather than separately because it is one fix: docs/qa/BOB-124/evidence/loginctl_user_state.txt is swallowed by *_user* at .gitignore:~55 and is therefore uncommitted §11.4.83 QA evidence. Its SIBLINGS IN THE SAME DIRECTORY — user1000_grepped.log, user_scope_events_head.log, user_service_lifecycle.log — ARE tracked, saved only by the

robust glob negation !docs/qa/**/*log. That one file is lost purely because it is .txt rather than .log. The pattern is exact: robust glob negations hold; per-file and per-extension rescues leak.

ACCEPTANCE: (1) both twins become trackable and are committed alongside their .md; (2) the BOB-124 .txt evidence likewise; (3) whichever BOB-212 fix direction is chosen, it MUST cover these — a fix that closes the future-swallow while leaving these three artifacts permanently uncommittable has addressed the mechanism and not the damage; (4) a check that a tracked .md in §11.4.65 scope has COMMITTABLE twins, so this class cannot recur silently.

DISCOVERY CHANNEL (§11.4.238): found by the BOB-212 blast-radius sweep — and only on its SECOND pass. The first pass filtered by a source-extension set that omitted .pdf, which hid this finding entirely; the agent re-ran with no extension filter over all 420 non-artifact paths and recorded the blind spot rather than shipping the first number. Worth keeping: an extension allowlist is itself a false-null generator, which is the same shape as the defect being investigated.

BOB-223 — §11.4.18 script-documentation and §11.4.44 revision headers are ungated — and the perverse consequence is that WRITING the mandated companion doc is what breaks the build

Status: Queued **Type:** Bug **Severity:** major

WHAT, both conductor-verified with control needles: CM-SCRIPT-DOCS-SYNC occurrences in scripts/pre_build_verification.sh = 0 (control needle CM-MARKDOWN-EXPORT-SYNC = 6, so the instrument sees). §11.4.44 revision-header enforcement likewise 0 hits (control needle 3). Neither §11.4.18's companion-doc mandate nor §11.4.44's revision header is enforced by any invariant.

THE PERVERSE CONSEQUENCE, MEASURED: a new script with NO companion doc passes the gate. Writing the companion doc that §11.4.18 MANDATES creates docs/scripts/.md, which invariant 16 (CM-MARKDOWN-EXPORT-SYNC) then requires to

have .html and .pdf twins — and their absence is a BLOCKING failure. This session hit it exactly: docs/scripts/test_gitignore_swallow_is_loud.{html,pdf} are missing and are two of invariant 16's six violations. So the gate's incentive gradient points AWAY from the constitution: complying with §11.4.18 is punished, ignoring it is free. That is worse than an ungated rule — it is a rule the machinery actively discourages.

§11.4.227 IS THE GOVERNING ANCHOR: a named gate that exists only in prose is gate debt, and the ledger of unimplemented CM-* names must be monotone-decreasing. CM-SCRIPT-DOCS-SYNC is named in §11.4.18's own text and implemented nowhere — one concrete row of exactly the 58%-unimplemented population §11.4.227 was minted to shrink.

ACCEPTANCE: (1) either CM-SCRIPT-DOCS-SYNC is implemented, or it is registered as a deferral pointing at a tracked §11.4.197 item — silent absence is what §11.4.227 forbids; (2) same for §11.4.44's header check; (3) whichever is chosen, the incentive inversion is closed: it must never be cheaper to skip a mandated doc than to write one — if invariant 16 will demand twins, the doc-creation path must produce them, or invariant 16 must scope out docs/scripts until it can; (4) a paired §1.1 mutation per gate implemented.

HONEST NOTE ON SCOPE: this item does not argue §11.4.18 should be enforced immediately — that is an operator call about gate debt priority (§11.4.66). It argues the CURRENT state is incoherent: an unenforced mandate whose observance triggers a different gate's failure. Either enforce both ends or neither.

DISCOVERY CHANNEL (§11.4.238): found by the T042 readiness preflight while explaining why a new file broke invariant 16. Not by the automated QA regime.

BOB-226 — Repair-side walk over foreign-owned INTERIOR directories is untested by any automated path

Status: Queued **Type:** Task **Severity:** major **Created-By:** Claude
Assigned-To: Claude

WHAT: ownership_repair walks a declared root and repairs items whose uid is not the operator. The unit suite seeds a foreign uid only onto FILES and SYMLINKS; interior DIRECTORIES stay operator-owned (case 22 seeds only a foreign declared ROOT, on the failure path). Production first-start repairs exactly the untested shape. MANIFEST: tests/unit/test_ownership_repair.sh seed_tree/seed_wrong; scripts/ownership_repair.sh walk at :994. REPRO: seed a tree whose interior directories carry uid 100000 via podman unshare, run the repair, observe no automated assertion covers the outcome. WHY UNTESTED: the unprivileged harness cannot create symlinks inside a directory it no longer owns, which cases 8/9/18 require. The DECLARED GAPS note cross-references tests/ownership/test_container_writes_owned_files.py, but that covers the CREATION side (FR-002), not the repair-side walk. ACCEPTANCE: an integration-layer test (where the unprivileged-harness constraint does not bind) that seeds foreign-owned interior directories, runs the repair, and asserts post-state ownership plus mode preservation. Surfaced by the BOB-207 independent review 2026-08-27.

BOB-231 — A gate asserting every executable a pre-build invariant invokes is itself tracked (BOB-227 criterion 2 follow-up)

Status: Queued **Type:** Task **Severity:** Major **Created-By:** AI

BOB-227 measured 3 of 4 artifacts of the CM-LAN-ROUTES-AUTHENTICATED gate untracked in git; criterion 1 (commit them) was already resolved by an unrelated prior commit before this session, closed 2026-09-23. Criterion 2 was NOT addressed: ‘a gate asserting that every executable a pre-build invariant invokes is itself tracked’ – a general mechanism preventing this whole CLASS of defect (a pre-build gate’s own implementation files shipping untracked, invisible to a fresh clone, no committed baseline for round-over-round diffs) from recurring for ANY future gate, not merely this one. ACCEPTANCE: (1) enumerate every file path scripts/pre_build_verification.sh invokes (via bash/timeout/python3 calls to scripts under scripts/pre_build/, plus every tests/pre_build/.sh and tests/hooks/.sh it runs) – likely via a static grep/parse of pre_build_verification.sh itself, or a runtime

trace; (2) assert every one of those paths is git-tracked (git ls-files --error-unmatch); (3) wire this as a new pre-build invariant so a future untracked gate implementation is caught immediately, not discovered independently weeks later; (4) a RED test creating an untracked fake gate-invocation target and asserting the new check fails on it, GREEN once the mechanism exists and the fake target is either removed or tracked.